

CVEs más relevantes de la semana

Del 29/08/2026 al 05/09/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-84135

Descripción: Other issue in Firefox Focus for Android. This vulnerability was fixed in Firefox 155.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-09-01



CVE-2026-84140

Descripción: Site isolation issue in the DOM: Navigation component. This vulnerability was fixed in Firefox 155, Firefox ESR 153.2, Thunderbird 155, and Thunderbird 153.2.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-346

Tecnología: No especificado

Publicado el: 2026-09-01



CVE-2026-84141

Descripción: Integer overflow in the Graphics: ImageLib component.
This vulnerability was fixed in Firefox 155, Firefox ESR 153.2,
Thunderbird 155, and Thunderbird 153.2.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-190

Tecnología: No especificado

Publicado el: 2026-09-01



CVE-2026-84142

Descripción: Internally found bugs present in Thunderbird 154. Some of these bugs showed evidence of memory corruption or another security-relevant defect and we presume that with enough effort some of these could have been exploited. This vulnerability was fixed in Firefox 155 and Thunderbird 155.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-09-01



CVE-2026-84143

Descripción: Internally found bugs present in Thunderbird 154, Thunderbird ESR 153.1 and Thunderbird ESR 140.14. Some of these bugs showed evidence of memory corruption or another security-relevant defect and we presume that with enough effort some of these could have been exploited. This vulnerability was fixed in Firefox 155, Firefox ESR 140.15, Firefox ESR 153.2, Thunderbird 155, Thunderbird 140.15, and ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-09-01



CVE-2026-85031

Descripción: A vulnerability was found in TOTOLINK CP450 4.1.0. The impacted element is an unknown function of the file /cgi-bin/cstecgi.cgi. Performing a manipulation of the argument topicurl results in buffer overflow. Remote exploitation of the attack is possible.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-09-03



CVE-2026-85183

Descripción: Taipy configures its socket.io server with wildcard CORS origin and credential flag enabled, allowing any web page to establish credentialed WebSocket connections to victim applications. Attackers can open socket.io sessions from arbitrary domains and invoke state variable modifications and action callbacks without CSRF protection.

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N

Tipo: CWE-1385

Tecnología: No especificado

Publicado el: 2026-09-03



CVE-2026-85394

Descripción: python-jose through 3.5.0 fails to properly validate asymmetric keys in HMAC initialization, accepting DER-encoded public keys that lack PEM armor or SSH prefixes. Attackers holding the service's public key can forge HS256 tokens that pass verification when algorithms are not explicitly restricted. This is an incomplete fix for CVE-2024-33663.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-347

Tecnología: No especificado

Publicado el: 2026-09-03



CVE-2026-85428

Descripción: MOOS core-moos through 10.4.0 contains an authentication bypass vulnerability in the optional MOOSDB HTTP server that allows unauthenticated clients to write variables. Attackers can send HTTP requests with variable names and values to the MOOSDB HTTP server port to modify MOOS variables including actuator and override commands without authentication.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-09-03



CVE-2026-85433

Descripción: MOOS essential-moos pShare through 10.0.1 fails to properly authorize PSHARE_CMD messages, allowing any publisher to reconfigure network routes and listeners at runtime. Attackers can send crafted PSHARE_CMD messages with cmd=output or cmd=input parameters to open new listeners on arbitrary addresses and redirect or duplicate bus traffic to attacker-controlled destinations.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-09-03



CVE-2026-85438

Descripción: MOOS-IvP through 24.8.1 contains a buffer overflow vulnerability in StringToIvPFunction() where dimension, piece, and degree counts from encoded BHV_IPF payloads are used as allocation sizes and loop bounds without validation. Attackers can supply crafted payloads with mismatched dimension values to write attacker-controlled doubles past the end of the IvPBox weight array, causing memory corrup...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-190

Tecnología: No especificado

Publicado el: 2026-09-03



CVE-2026-11613

Descripción: The Divi Ajax Filter plugin for WordPress is vulnerable to Local File Inclusion in all versions up to, and including, 5.1.2 via the 'custom_loop_template' parameter parameter. This makes it possible for unauthenticated attackers to include and execute arbitrary .php files on the server, allowing the execution of any PHP code in those files. This can be used to bypass access controls, obtain sen...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-98

Tecnología: No especificado

Publicado el: 2026-09-04



CVE-2026-85661

Descripción: excel-mcp-server 0.1.8 fails to enforce path confinement in stdio mode when EXCEL_FILES_PATH is unset, allowing attackers to read and write arbitrary files. Attackers can supply unchecked file paths to read and write tools to access any file accessible to the process.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-09-04



CVE-2026-85667

Descripción: xiaobei through 5.5.2 fails to implement authentication or signature validation on webhook endpoints, allowing unauthenticated attackers to inject arbitrary messages into the agent pipeline. Attackers can publish malicious messages via the /webhook_worktool handler and exploit unvalidated media URL fetching to perform server-side request forgery against internal services.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-09-04



CVE-2026-85672

Descripción: zerox 1.1.20 contains an OS command injection vulnerability in the file download mechanism where the temporary file extension derived from document URLs is interpolated unsanitized into shell commands executed by poppler utilities.

Attackers can craft document URLs with malicious file extensions containing command substitution syntax to execute arbitrary OS commands before document processing o...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-09-04



CVE-2026-85684

Descripción: marker through 2.0.0 contains a path traversal vulnerability in the FastAPI /marker/upload handler that fails to sanitize the file.filename parameter. Unauthenticated attackers can supply filenames containing directory traversal sequences to write arbitrary files to any location or delete existing files on the system.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-73

Tecnología: No especificado

Publicado el: 2026-09-04



CVE-2026-85688

Descripción: TEN Framework 0.11.71 contains unauthenticated arbitrary file read and write vulnerabilities in the TMAN Designer file-content API endpoints. Attackers can submit POST and PUT requests to the `/api/designer/v1/file-content` endpoints to read arbitrary files or write malicious content to system paths, enabling code execution through `authorized_keys`, cron files, or executable graph files.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-09-04



CVE-2026-85695

Descripción: FastChat contains an authentication bypass vulnerability in the /register_worker endpoint that allows unauthenticated attackers to register arbitrary worker addresses and perform server-side request forgery. Attackers can register malicious workers under victim model names to intercept user prompts, images, and responses, or probe internal network ports across the worker mesh.

CVSS: 9.4 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-09-04



CVE-2026-85696

Descripción: SadTalker contains an OS command injection vulnerability in the video muxing process where uploaded audio filenames are interpolated into ffmpeg commands without proper escaping. Attackers can upload audio files with shell metacharacters in the filename to break out of quoted arguments and execute arbitrary system commands when video generation occurs.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-09-04



CVE-2026-18658

Descripción: IBM Operational Decision Manager 9.6.0.0, 9.5.0.0, 8.11.1.0, 8.11.0.1, 8.12.0.1, 9.5.0.1, and 9.0.0.1 is vulnerable to SQL injection. An unauthenticated attacker can execute arbitrary SQL statements and leverage database functionality to write a web shell to the application web root, resulting in remote code execution.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-09-04



CVE-2026-13447

Descripción: The Mstore Api plugin for WordPress is vulnerable to Authentication Bypass via JWT Forgery in versions up to, and including, 4.20.0 This is due to missing cryptographic signature verification in the `FirebasePhoneAuthHelper::verify_id_token()` function, which decodes and validates Firebase ID token claims (alg, kid, aud, iss) but never calls `openssl_verify()` or any equivalent to validate the JWT ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-09-05



CVE-2026-83627

Descripción: The Hummingbird – Speed Optimization, Caching, Minify, Compress & CDN plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 3.21.0 via the log_msg() function in core/modules/class-page-cache.php. The page-cache debug log is written to wp-content/wphb-logs/page-caching-log.php, a directly web-accessible PHP file that is supposed to be protected by a le...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-09-05



CVE-2024-11080

Descripción: The Post Grid and Gutenberg Blocks – ComboBlocks plugin for WordPress is vulnerable to Unauthenticated Hook Injection in versions 2.2.32 to 2.3.1 via several functions in the `~/includes/blocks/form-wrap/function.php` file. This makes it possible for unauthenticated attackers to execute actions with hooks in WordPress, granted no other security controls are present in the function.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-09-05



CVE-2026-86121

Descripción: Cua computer-server versions before 0.3.42 skip authentication when the CONTAINER_NAME environment variable is unset and bind to all interfaces by default, allowing unauthenticated attackers to execute arbitrary commands. Attackers can reach TCP port 8000 to run shell commands via the run_command endpoint, read and write arbitrary files through file operation endpoints, and access interactive P...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-09-05



CVE-2026-86124

Descripción: AutoAgent contains an unauthenticated remote code execution vulnerability in the TCP server that binds to all interfaces and executes attacker-supplied commands as root. Attackers can connect to the exposed communication port and execute arbitrary bash commands within the container, gaining access to bind-mounted host workspace directories.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-09-05



CVE-2026-10196

Descripción: The Mail Mint – Email Marketing, Newsletter, Email Automation & WooCommerce Emails plugin for WordPress is vulnerable to PHP Object Injection in all versions up to, and including, 1.31.0 via deserialization of untrusted input in the 'handle_form_submission' function. This makes it possible for unauthenticated attackers to inject a PHP Object. The additional presence of a POP chain allows attack...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-09-05



CVE-2026-86184

Descripción: Lara Dashboard before 1.3.0 contains an authentication bypass vulnerability in the screenshot-login route that allows unauthenticated attackers to authenticate as any user by email when APP_ENV is not production. Attackers can request the GET /screenshot-login/{email} endpoint with a registered email address to receive a fully authenticated session, enabling access to user administration, setti...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-09-05



CVE-2026-86189

Descripción: WBN AVideo contains a path traversal vulnerability in notify.ffmpeg.json.php that allows unauthenticated attackers to write files to arbitrary locations by supplying a caller-chosen path in the avideoRelativePath parameter. Attackers can replay any previously issued ciphertext as a notifyCode token, which is decrypted but never validated, to bypass authentication and write files to the applica...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-73

Tecnología: No especificado

Publicado el: 2026-09-05



CVE-2026-86190

Descripción: WWBN AVideo contains a broken access control vulnerability in videoViewsInfo endpoints that returns complete user records including password hashes, recovery tokens, and live session identifiers to unauthenticated callers when a hash parameter is provided. Attackers can use the disclosed session identifier to hijack viewer sessions, including administrator accounts, and obtain sensitive persona...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-200

Tecnología: No especificado

Publicado el: 2026-09-05



Resumen del Reporte

CVEs analizados: 29

Promedio CVSS: 9.68

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

